

WEEK 6 DELIVERABLE

PaySphere SOC 2 Readiness and Third-Party Assurance Assessment

Project Areas: SOC 2 Readiness Assessment & Vendor Risk Review

Prepared by: GRC Analyst

Date: August 2026

Organization: PaySphere (Simulated Case Study)

1. Executive Overview

Project Purpose

This Week 6 deliverable demonstrates the application of Governance, Risk, and Compliance (GRC) and Third-Party Risk Management (TPRM) concepts through two integrated assessments conducted for PaySphere, a simulated Series B fintech organization.

The objective was to evaluate PaySphere's readiness for a SOC 2 Type II examination and assess the reliability of a critical third-party vendor's SOC 2 Type II report.

The project consists of two connected workstreams:

Project A — SOC 2 Readiness Gap Assessment

Assessment of PaySphere's existing security and governance environment against the SOC 2 Trust Services Criteria for Security, covering Common Criteria CC1 through CC9.

Project B — Razorpay SOC 2 Type II Vendor Risk Review

Detailed assessment of a simulated SOC 2 Type II report provided by PaySphere's critical payment processing vendor, including opinion analysis, scope assessment, exceptions, CUECs, subservice organization dependencies, and resulting vendor risk actions.

Together, these projects demonstrate how a GRC or TPRM analyst connects:

- Organizational risks
- Control requirements
- SOC 2 criteria
- Control gaps
- Vendor dependencies
- Complementary User Entity Controls (CUECs)
- Audit evidence requirements
- Risk remediation priorities

2. Business and Technology Context

PaySphere is a simulated Series B fintech organization with approximately 40 employees.

The organization operates in a high-risk environment due to its dependency on cloud infrastructure and third-party services for payment processing and business operations.

Technology Environment

Area	Environment
Primary Cloud Provider	AWS Mumbai
Payment Processing	Razorpay
OTP / Communications	Twilio
Customer Relationship Management	Salesforce
Internal Communications	Slack
Source Code Management	GitHub
Primary Cloud Environment	AWS
Approximate Workforce	40 Employees

Current GRC Maturity

At the start of the assessment, PaySphere had:

- No formal ISMS
- No SOC 2 compliance program
- No formal GRC governance structure
- No documented enterprise-wide Information Security Policy
- No centralized control library
- No formal security steering committee
- No mature control monitoring program

However, a security risk register containing risks PSR-001 through PSR-009 had already been established.

The purpose of this assessment was therefore not to start from zero, but to determine whether the existing security environment could support a future SOC 2 Type II examination.

PART I — PROJECT A

PAYSPHERE SOC 2 READINESS GAP ASSESSMENT

3. Assessment Objective

The objective of the SOC 2 readiness assessment was to identify gaps between PaySphere's existing control environment and the SOC 2 Trust Services Criteria for Security.

The assessment focused on the Common Criteria:

- CC1 — Control Environment
- CC2 — Communication and Information
- CC3 — Risk Assessment
- CC4 — Monitoring Activities
- CC5 — Control Activities
- CC6 — Logical and Physical Access Controls
- CC7 — System Operations
- CC8 — Change Management
- CC9 — Risk Mitigation

The assessment evaluated three primary questions for each criterion:

1. What currently exists?
 2. What gap prevents SOC 2 readiness?
 3. What remediation is required before the audit period can begin?
-

4. Overall Readiness Assessment

Overall Readiness Rating

NOT READY TO BEGIN SOC 2 TYPE II AUDIT PERIOD

PaySphere has several operational security controls in place; however, the control environment lacks the governance, documentation, evidence collection, monitoring, and formal control processes required for SOC 2 readiness.

The most significant gaps relate to:

- Privileged access management
- Network security
- Change management

- Endpoint security
- Incident response
- Monitoring
- Governance
- Vendor risk management

Estimated Readiness Timeline

Milestone	Estimated Timeline
Critical remediation	Immediate to 4 weeks
High-priority remediation	1–2 months
Governance and evidence maturity	2–3 months
Readiness before audit period	Approximately 4–5 months
SOC 2 Type II observation period	Approximately 6–12 months
Estimated first SOC 2 Type II report	Approximately 14–18 months

Evidence Infrastructure Recommendation

A compliance automation platform such as Sprinto or Vanta should be implemented at the beginning of remediation.

For an organization of approximately 40 employees without a dedicated GRC team, centralized evidence collection is a practical requirement rather than an optional enhancement.

The platform would support:

- Policy acknowledgments
- Evidence collection
- Control ownership
- Control testing
- Access review evidence
- Vendor documentation
- Compliance monitoring

5. SOC 2 Readiness Findings

CC1 — Control Environment

Current State

PaySphere lacks:

- A formal Information Security Policy

- A documented Security Steering Committee
- A documented board-level security mandate
- A security awareness training program
- A formal security RACI
- A documented security reporting relationship to executive leadership

Gap

The organization's security governance is not formally established.

This creates a foundational weakness because the reliability of downstream controls depends on management commitment, accountability, and governance.

Without a defined control environment, auditors may have reduced confidence in the design and operation of controls across CC6 through CC9.

Required Remediation

- Develop and obtain approval for an Information Security Policy
- Establish a Security Steering Committee
- Define quarterly security governance meetings
- Implement security awareness training during onboarding and annually
- Establish a documented RACI for security responsibilities
- Formalize executive and board-level security reporting

Severity

HIGH

Related Risk

PSR-008 — Information Security / GRC Maturity Gap

CC2 — Communication and Information

Current State

PaySphere does not have a formal mechanism for:

- Communicating security policies to employees
- Capturing employee acknowledgment
- Communicating security expectations externally
- Reporting security information to leadership on a defined schedule

Gap

Security controls and policies must not only exist; they must be communicated and acknowledged.

The absence of evidence showing employee acknowledgment would prevent PaySphere from demonstrating that security expectations are understood across the organization.

Required Remediation

- Distribute policies through a centralized compliance platform
- Capture employee acknowledgments electronically
- Include relevant security commitments in customer and vendor agreements
- Establish monthly security reporting to leadership
- Develop security Key Risk Indicators (KRIs)

Severity

MEDIUM

Related Risk

PSR-008

CC3 — Risk Assessment

Current State

PaySphere has an existing risk register containing PSR-001 through PSR-009.

However, the organization lacks a formally documented methodology describing:

- Risk identification
- Asset identification
- Threat analysis
- Likelihood scoring
- Impact scoring
- Residual risk determination
- Risk treatment
- Risk acceptance
- Review frequency

Fraud risk is also not formally established as a dedicated assessment category.

Gap

A risk register alone is insufficient evidence of an effective risk management process.

SOC 2 requires evidence demonstrating how risks were identified, assessed, treated, and monitored.

Required Remediation

Develop a formal methodology covering:

Asset Identification → Threat Identification → Likelihood Assessment → Impact Assessment → Risk Rating → Residual Risk → Treatment Decision → Review

Additional actions include:

- Establishing annual formal risk assessments
- Documenting CISO and management approval
- Explicitly incorporating fraud risk
- Documenting formal risk acceptance decisions
- Establishing review triggers for significant environmental changes

Severity

MEDIUM

Related Risks

All PaySphere security risks.

CC4 — Monitoring Activities

Current State

PaySphere does not have a mature monitoring environment.

The following controls are absent or not confirmed:

- SIEM capability
- AWS Security Hub
- AWS GuardDuty
- Centralized KRI monitoring
- Formal control testing calendar
- Defined escalation process for control failures

Gap

Controls that are not monitored can fail without detection.

The absence of monitoring creates cascading risk because failures in access, network, endpoint, and operational controls may remain undetected.

Required Remediation

- Enable AWS Security Hub
- Enable AWS GuardDuty
- Enable CloudTrail across relevant regions
- Implement log integrity validation
- Establish monthly KRI reviews
- Create a quarterly control testing calendar
- Define escalation procedures for control deficiencies

Severity

HIGH

Related Risks

- PSR-006
 - PSR-007
-

CC5 — Control Activities

Current State

Operational security controls exist but are not formally documented as a centralized control framework.

Examples include:

- Razorpay webhook validation
- Twilio OTP functionality
- AWS encryption controls

However, PaySphere does not maintain:

- A control library
- Formal control owners
- Risk-to-control mapping
- TSC-to-control mapping
- Evidence requirements
- Testing frequency
- Policy-to-procedure hierarchy

Gap

Controls operating in practice cannot be effectively audited if they are undocumented.

An auditor must be able to trace:

Risk → Control → SOC 2 Criterion → Evidence → Testing

Required Remediation

Build a formal control library containing:

- Control description
- Control owner
- Related risk
- SOC 2 criterion
- Evidence requirement
- Testing frequency
- Review frequency

Establish a policy hierarchy:

Policy → Standard → Procedure

Severity

MEDIUM

6. CC6 — Logical and Physical Access Controls

CC6 represented the highest-risk area of the assessment and was therefore assessed at the sub-criterion level.

CC6.1 — Provisioning and Least Privilege

Current State

PSR-001 identified:

- Persistent production database access
- Excessive privileges
- No Just-in-Time Privileged Access Management
- No documented RBAC matrix
- No formal access request workflow
- No documented approval process

Gap

PaySphere would be unable to demonstrate that access is:

- Requested
- Approved
- Appropriate for the user's role
- Limited by least privilege
- Removed when no longer required

Persistent privileged database access creates a direct security exposure.

Required Remediation

- Implement JIT PAM
- Develop RBAC matrices
- Implement access request and approval workflows
- Require manager and system owner approval
- Apply access expiration where appropriate
- Perform quarterly access certification

Severity

CRITICAL

Related Risk

PSR-001

CC6.2 — Authentication

Current State

MFA may be required by policy, but technical enforcement is not confirmed.

Potential risks include:

- Users authenticating without MFA
- Legacy authentication protocols bypassing MFA
- Insufficient evidence of MFA enrollment

Required Remediation

- Enforce MFA at the identity provider level
- Disable legacy authentication protocols where applicable
- Produce recurring MFA compliance reports
- Apply stronger authentication to privileged accounts

Severity

HIGH

Related Risk

PSR-001

CC6.3 — Deprovisioning

Current State

PaySphere lacks a centralized offboarding process covering:

- Google Workspace
- Salesforce
- Slack
- GitHub
- AWS
- Razorpay
- Twilio

A shared Razorpay dashboard login further prevents individual deprovisioning.

Gap

The organization cannot reliably demonstrate that terminated employees lose access to all systems within an established timeframe.

This also directly connects to the Razorpay CUEC finding involving shared dashboard credentials.

Required Remediation

Develop a master offboarding workflow covering all in-scope systems.

The workflow should:

- Be triggered by HR
- Include timestamps
- Track completion
- Define ownership
- Require removal within 24 hours
- Be subject to quarterly access reviews

Severity

HIGH

Related Risks

- PSR-001
 - Razorpay CUEC-04
-

CC6.4 — Physical Access

Current State

PaySphere relies on AWS for data center infrastructure.

AWS physical data center controls are outside PaySphere's direct responsibility, but PaySphere remains responsible for:

- Office access
- Visitor management
- Network equipment
- Employee devices

Required Remediation

- Document office access procedures
- Maintain visitor logs
- Secure network equipment
- Implement device management
- Enforce full-disk encryption

Severity

MEDIUM

Related Risk

PSR-005

CC6.5 — Physical and Logical Termination Alignment

Current State

Physical access and logical access termination processes are not integrated.

Gap

A terminated employee could lose physical access immediately while retaining logical access for several days.

Required Remediation

Implement a single HR-triggered termination process that initiates both:

- Physical access removal
- Logical access removal

Both actions should be tracked in the same termination record.

Severity

MEDIUM

CC6.6 — Network Controls

Current State

PSR-007 identified:

- No confirmed WAF protecting the merchant portal
- No documented network segmentation
- No formal firewall review cadence
- No confirmed secure remote administration model

Gap

The public-facing merchant portal may be exposed to application-layer attacks.

Lack of segmentation also increases the risk of lateral movement between development and production environments.

Required Remediation

- Deploy AWS WAF
- Establish production, development, and management network segmentation
- Restrict administrative access
- Prevent direct administrative access to production systems
- Review security group and firewall rules quarterly

Severity

CRITICAL

Related Risk

PSR-007

CC6.7 — Encryption

Current State

Encryption may be enabled within AWS but has not been formally verified and documented.

Other gaps include:

- Unknown TLS configuration
- No centralized device encryption verification
- No encryption standard
- No documented key management requirements

Required Remediation

- Verify TLS configuration
- Disable obsolete protocols
- Verify encryption for S3, RDS, EBS, and backups
- Deploy MDM
- Enforce full-disk encryption
- Establish encryption and key management standards

Severity

HIGH

Related Risks

- PSR-005
 - PSR-007
-

CC6.8 — Malware Prevention

Current State

PaySphere lacks centralized endpoint management.

Without MDM, the organization cannot reliably demonstrate:

- Endpoint coverage

- EDR installation
- EDR health
- Malware detection coverage

Required Remediation

- Deploy MDM
- Deploy centrally managed EDR
- Enforce EDR enrollment
- Monitor endpoint coverage
- Produce recurring coverage reports
- Restrict unauthorized software installation

Severity

HIGH

Related Risk

PSR-005

7. CC7 — System Operations

Current State

PaySphere lacks:

- Formal SIEM capability
- Confirmed GuardDuty and Security Hub deployment
- Incident Response Plan
- On-call management
- Post-incident review process
- Documented tabletop exercises

Gap

An incident could currently be handled without:

- Defined escalation
- Defined ownership
- Consistent containment
- Documented communication
- Formal post-incident learning

Required Remediation

- Enable GuardDuty
- Enable Security Hub
- Configure centralized alerting
- Implement on-call management
- Develop an Incident Response Plan
- Define incident severity levels
- Create escalation procedures
- Conduct a tabletop exercise
- Establish post-incident review requirements

Severity

HIGH

Related Risks

- PSR-006
 - PSR-007
-

8. CC8 — Change Management

Current State

The secure software development and change management environment is not formally established.

The following controls are not confirmed:

- GitHub branch protection
- Mandatory peer review
- Staging environment
- Formal change approval
- Emergency change procedure
- Rollback planning

Gap

Unauthorized or untested changes could reach production.

For a payment processing organization, this represents both a security and business continuity risk.

Required Remediation

- Require pull requests
- Require peer review

- Require automated status checks
- Block direct pushes to protected branches
- Establish staging environments
- Track changes through Jira or an equivalent system
- Document emergency change procedures
- Require post-deployment review

Severity

CRITICAL

Related Risk

PSR-007

9. CC9 — Risk Mitigation and Vendor Risk Management

Current State

PaySphere has a formal vendor risk record for Razorpay but not for:

- AWS
- Twilio
- Salesforce
- Slack

Additional gaps include:

- No formal vendor onboarding process
- No formal annual vendor review program
- Unverified security clauses in vendor contracts
- No documented cyber insurance review

A significant additional finding was vendor concentration within the subservice layer.

Razorpay and Twilio both depend on AWS infrastructure, while PaySphere also directly depends on AWS.

This creates deeper cloud concentration than would be visible by examining only direct vendors.

Required Remediation

- Complete vendor risk records for all critical vendors

- Obtain and review relevant assurance reports
- Establish vendor onboarding requirements
- Establish annual vendor reassessment
- Review contracts for security requirements
- Assess breach notification requirements
- Review data protection obligations
- Identify subservice concentration risks
- Assess cyber insurance as a potential risk transfer mechanism

Severity

HIGH

Related Risks

- PSR-002
- PSR-002a
- PSR-002b
- PSR-002c

10. Consolidated SOC 2 Readiness Summary

Severity	Key Findings
CRITICAL	Privileged access management, network controls, change management
HIGH	Control environment, monitoring, MFA, deprovisioning, encryption, endpoint protection, incident response, vendor risk
MEDIUM	Communication, risk methodology, control documentation, physical access, termination alignment

Primary Readiness Conclusion

PaySphere should not begin its SOC 2 Type II audit period until Priority 1 and Priority 2 remediation activities are complete.

The primary objective of remediation should be to establish:

1. Technically effective controls
 2. Documented governance
 3. Repeatable processes
 4. Evidence collection
 5. Control monitoring
-

11. SOC 2 Remediation Roadmap

Phase 1 — Immediate Actions

- Enable AWS GuardDuty
 - Enable AWS Security Hub
 - Enable CloudTrail
 - Enforce MFA
 - Enable GitHub branch protection
 - Implement compliance evidence infrastructure
-

Phase 2 — Priority 1 Remediation

- Deploy JIT PAM
 - Implement RBAC
 - Deploy AWS WAF
 - Segment production, development, and management environments
 - Establish privileged access workflows
 - Develop the Information Security Policy
-

Phase 3 — Priority 2 Remediation

- Deploy MDM
 - Enforce full-disk encryption
 - Deploy EDR
 - Implement offboarding procedures
 - Implement quarterly access reviews
 - Develop Incident Response Plan
 - Establish on-call alerting
 - Conduct tabletop exercises
-

Phase 4 — Governance and Maturity

- Document risk assessment methodology
- Establish control library
- Implement KRI reporting
- Establish control testing calendar
- Complete vendor risk assessments
- Review vendor contracts
- Formalize risk acceptance

PART II — PROJECT B

RAZORPAY SOC 2 TYPE II VENDOR RISK REVIEW

12. Vendor Review Objective

Razorpay is a critical vendor because PaySphere relies on the organization for payment processing.

The purpose of this review was to determine:

- Whether the SOC 2 Type II report can be relied upon
 - Whether the report provides current assurance
 - Whether identified exceptions affect PaySphere
 - Whether CUECs have been implemented
 - Whether subservice organization dependencies create additional risk
 - What remediation and escalation actions are required
-

13. Vendor Risk Record

Field	Assessment
Vendor	Razorpay Software Private Limited
Risk Record	VRR-002b
Vendor Criticality	CRITICAL
Service	Payment Processing
Report Reviewed	SOC 2 Type II
Opinion	Qualified
Review Date	August 2026

14. Executive Vendor Risk Conclusion

Overall Reliance Posture

CANNOT RELY ON THE REPORT FOR CURRENT ASSURANCE — ESCALATION REQUIRED

Five material concerns were identified:

1. Qualified SOC 2 opinion
2. Significant report period gap
3. Scope limitations
4. Unmet PaySphere CUECs
5. Partial implementation of additional customer controls

Because Razorpay is PaySphere's critical payment processor, these issues require active tracking and management.

15. SOC 2 Opinion Assessment

The report contains a **qualified opinion**.

A qualified opinion indicates that most controls may have operated effectively, but material exceptions were identified.

The two exceptions were:

- CC6.3-01 — Deprovisioning failures
- A1.3-01 — No Disaster Recovery test during the audit period

These findings prevent unconditional reliance on the report.

16. Report Period Assessment

The report covered:

April 1, 2024 – September 30, 2024

At the time of review, the report was approximately 22 months old.

This is a material assurance gap.

A bridge letter cannot reasonably provide sufficient assurance over such a long period.

The appropriate TPRM response is:

- Request the current SOC 2 Type II report
- Request the next report's coverage period

- Request remediation evidence for prior exceptions
 - Request supplemental evidence where current assurance documentation is unavailable
-

17. Scope Assessment

Criteria Included

- Security
- Availability
- Processing Integrity

Criteria Not Included

- Confidentiality
- Privacy

Confidentiality Gap

Merchant contract information, settlement information, and business-sensitive data may be subject to confidentiality obligations.

Because Confidentiality was outside the SOC 2 scope, the report does not provide assurance regarding whether such information is classified and protected according to contractual confidentiality commitments.

This represents a residual assurance gap.

18. Subservice Organization Dependency

AWS was identified as a subservice organization excluded from Razorpay's SOC 2 examination.

Therefore, Razorpay's report does not provide assurance over AWS infrastructure and physical data center controls.

PaySphere must maintain separate infrastructure assurance through AWS documentation and its own vendor risk review.

This also connects directly to the CC9 gap identified in Project A.

19. Exception Analysis

Exception 1 — CC6.3-01

Finding

Four out of thirty terminated employees retained access beyond the required 24-hour deprovisioning SLA.

Access remained active between:

3 and 14 days

Risk

Terminated employees may have retained access to systems involving merchant or transaction data.

Potential risks include:

- Unauthorized access
- Insider activity
- Data exposure
- Credential misuse

Severity for PaySphere

HIGH

Required Action

- Request remediation evidence
- Confirm whether automation has been implemented
- Verify resolution in the next SOC 2 report
- Maintain the finding as open in VRR-002b

Exception 2 — A1.3-01

Finding

No Disaster Recovery test was conducted during the SOC 2 audit period.

Razorpay's stated objectives were:

- RTO: 4 hours

- RPO: 1 hour

However, these objectives were not validated during the audit period.

Risk to PaySphere

PaySphere processes approximately ₹500 Cr per month through Razorpay.

If Razorpay experiences a significant outage, PaySphere's payment operations may be materially disrupted.

This is compounded by PaySphere's own BCDR gap.

Severity for PaySphere

CRITICAL

Required Action

- Escalate to the CISO
- Request recent DR testing evidence
- Request test results and remediation evidence
- Document that stated RTO and RPO commitments cannot currently be independently relied upon
- Accelerate PaySphere's own BCDR planning

20. CUEC Assessment

CUECs are controls that Razorpay requires PaySphere to implement.

Failure to implement these controls creates a break in the end-to-end control environment.

CUEC	PaySphere Status	Severity
Credential confidentiality	PARTIAL	MEDIUM
IP allowlisting	NOT MET	HIGH
Webhook validation	MET	—
Dashboard RBAC	NOT MET	CRITICAL
Transaction anomaly monitoring	NOT MET	HIGH
Tokenization / PCI scope	PARTIAL	MEDIUM

CUEC-01 — Credential and Secret Protection

Finding

API keys are stored without a centralized secrets management process.

Key rotation is not formally documented.

Risk

A compromised development environment may expose credentials with access to production services.

Required Action

- Implement centralized secrets management
- Separate production and development credentials
- Establish credential rotation requirements

Severity

MEDIUM

CUEC-02 — API IP Allowlisting

Finding

Razorpay API access is not restricted to authorized server IP addresses.

Risk

A compromised credential could potentially be used from an unauthorized environment.

Required Action

Configure IP allowlisting for authorized PaySphere production systems.

Severity

HIGH

CUEC-03 — Webhook Validation

Finding

Webhook signature validation was confirmed.

Payment status updates are processed only after signature verification.

Status

MET

No immediate remediation required.

CUEC-04 — Dashboard Role-Based Access

Finding

PaySphere uses a shared Razorpay dashboard login.

Risks

This creates multiple control failures:

- Individual actions cannot be attributed
- Individual access cannot be removed
- Least privilege cannot be enforced
- Shared credentials increase accountability risk

Required Action

- Create individual accounts
- Remove shared credentials
- Assign role-based permissions
- Establish access review procedures

Severity

CRITICAL

Related Risks

- PSR-001
 - PaySphere CC6.3 readiness gap
-

CUEC-05 — Transaction Anomaly Monitoring

Finding

Transaction anomaly monitoring is not configured.

Risk

At PaySphere's transaction volume, abnormal transaction patterns may remain undetected until manual review.

Required Action

Implement monitoring for:

- Unusual transaction volumes
- Unusual refund patterns
- High-value transactions
- Fraud indicators

Severity

HIGH

CUEC-06 — Tokenization and PCI DSS Scope

Finding

Tokenization is implemented.

However, PaySphere's Cardholder Data Environment boundary is not formally documented.

Risk

Without formally defining the CDE, PaySphere cannot demonstrate that:

- Raw card data is excluded from its environment
- Tokenization is consistently applied
- All payment flows are correctly scoped

Required Action

Perform a formal PCI DSS scoping exercise.

Severity

MEDIUM

21. Vendor Risk Remediation Plan

Immediate Actions

- Remove the shared Razorpay dashboard login
 - Create individual user accounts
 - Escalate the Disaster Recovery finding to the CISO
 - Request the current SOC 2 Type II report
 - Request current DR testing evidence
 - Request remediation evidence for the deprovisioning exception
-

Short-Term Actions

- Implement API IP allowlisting
 - Configure transaction anomaly alerts
 - Implement secrets management
 - Review AWS assurance documentation
-

Medium-Term Actions

- Complete PCI DSS scope assessment
 - Complete AWS vendor risk review
 - Review confidentiality assurance requirements
 - Establish ongoing vendor monitoring
-

22. Updated Vendor Risk Posture

Field	Status
Vendor Criticality	CRITICAL
SOC 2 Opinion	Qualified
Report Currency	Significantly outdated
Current Assurance	Cannot be relied upon
Deprovisioning Finding	HIGH
DR Testing Finding	CRITICAL
Unmet CUECs	3 identified
Partially Met CUECs	2 identified
Escalation Required	Yes
Risk Owner	CISO

23. Key GRC and TPRM Outcomes

This project demonstrates several important analytical capabilities relevant to a GRC Analyst or Third-Party Risk Analyst role.

Risk-to-Control Traceability

Security gaps were connected directly to:

- Existing risk records
 - SOC 2 criteria
 - Control failures
 - Remediation activities
-

SOC 2 Readiness Assessment

The project evaluated readiness across the complete Security Common Criteria framework rather than reviewing isolated technical controls.

Third-Party Risk Analysis

The vendor review extended beyond simply checking whether a SOC 2 report existed.

The assessment considered:

- Opinion type
 - Report period
 - Exceptions
 - Scope
 - CUECs
 - Subservice organizations
 - Vendor concentration
 - Downstream business impact
-

Residual Risk Analysis

The most significant analytical outcome was the identification of cascading risk.

For example:

Razorpay DR testing failure → Unverified RTO/RPO → Payment processing dependency → PaySphere operational impact → Amplified by PaySphere's own BCDR gap.

This demonstrates that vendor findings should not be assessed in isolation.

Their impact must be evaluated within the organization's own dependency and control environment.

24. Final Conclusion

PaySphere is not currently ready to begin a SOC 2 Type II audit period.

The organization has several operational security controls, but these controls require formalization, technical enforcement, centralized monitoring, documented ownership, and repeatable evidence collection.

The highest-priority remediation areas are:

1. Privileged access management
2. Network security
3. Change management
4. MFA enforcement
5. Endpoint security
6. Incident response
7. Control monitoring
8. Vendor risk management

The Razorpay vendor assessment further demonstrates that third-party assurance cannot be evaluated solely by confirming the existence of a SOC 2 report.

Effective TPRM requires evaluation of:

Report Currency → Opinion → Scope → Exceptions → CUECs → Subservice Organizations → Business Dependency → Residual Risk

The combined findings provide PaySphere with a practical remediation roadmap for improving SOC 2 readiness while simultaneously strengthening its third-party risk management program.

Portfolio Summary

Week 6 Deliverable: PaySphere SOC 2 Readiness and Third-Party Assurance Assessment

Skills Demonstrated

- SOC 2 Trust Services Criteria assessment
- Control gap analysis
- Risk assessment methodology

- Risk-to-control mapping
- Access control assessment
- Privileged access management analysis
- Incident response assessment
- Change management assessment
- Security monitoring evaluation
- Vendor SOC 2 review
- Qualified opinion analysis
- SOC report scope analysis
- Audit period currency assessment
- CUEC analysis
- Subservice organization analysis
- Vendor risk assessment
- Residual risk analysis
- Remediation planning
- Risk prioritization and escalation

Final Deliverables Produced

Project A: SOC 2 Security Criteria Readiness Gap Assessment and Remediation Roadmap

Project B: Razorpay SOC 2 Type II Vendor Risk Findings Memo and Updated Vendor Risk Assessment

Overall Outcome

The project resulted in a structured remediation roadmap that connects PaySphere's internal security control gaps with third-party assurance dependencies and provides a prioritized path toward SOC 2 Type II readiness.